Semana 09 — Respuesta a incidentes y triage estático de malware

Fase 4: Forense y respuesta a incidentes — instrucciones paso a paso

Prof. César Rodríguez | ELECTRONICA | 1 de noviembre de 2026

Curso	CYBERSEGURIDAD — Ciberseguridad Aplicada
Semana	09 de 10
Fase	4 — Forense y respuesta a incidentes
Modalidad	4 grupos, trabajo desde sus propios equipos
Dedicación	4 horas de laboratorio + 2 horas de estudio independiente
Instrumento	Actividad formativa
Entrega	GitHub, carpeta semana_09/
Corte	Domingo 23:59 de la semana correspondiente; lo posterior no se corrige.

1 Antes de la sesión

Estas tareas se hacen en casa, antes de la práctica. Si el repositorio o el laboratorio no están listos al empezar, la sesión se va en arreglarlos y no alcanza para el informe.

1. Comprobar que el repositorio del grupo tiene la carpeta semana_09 creada.
2. Revisar la retroalimentación del docente sobre la semana anterior y corregir lo pendiente.
3. Traer instaladas las herramientas de la semana: file y strings, YARA, sha256sum.
4. Confirmar que el laboratorio arranca y que los tres servicios responden antes de la sesión.
5. Leer el objetivo y los contenidos para llegar con el vocabulario de la práctica.

2 Objetivo de la semana

Aplicar un playbook de respuesta y realizar triage estático de una muestra inerte sin ejecutarla.

3 Contenidos que se aplican

- NIST SP 800-61: preparación, detección, contención, erradicación y recuperación.
- Playbooks, roles, comunicación y registro de decisiones.
- Triage estático con hashes, strings, cabeceras y reglas YARA.
- Límites legales y técnicos del análisis dinámico.
- Informe post mortem y acciones de mejora.

4 Escenario

Cada grupo escribe el playbook del incidente reconstruido en la semana 8 y realiza triage estático de una muestra inerte entregada por el docente.

5 Paso a paso de la práctica

1. Redactar el playbook en una página con fases, responsables y criterios de escalado.
2. Calcular el hash de la muestra y buscar su reputación sin subir datos sensibles.
3. Extraer cadenas relevantes e identificar indicios de funcionalidad.
4. Escribir una regla YARA que detecte la muestra y probarla contra ella.
5. Redactar el post mortem con acciones de mejora priorizadas.

Concepto clave

Regla de oro de la evidencia: guarda la salida de cada paso en `semana_09/evidencia/` en el momento en que la obtienes. Reconstruirla después no es evidencia, es memoria.

Herramientas de la semana: file y strings, YARA, sha256sum.

6 Rol de cada grupo esta semana

Todos los grupos resuelven la misma práctica, cada uno en su propio repositorio y su propio laboratorio: el trabajo de un grupo no depende del de otro. El rol cambia el énfasis del trabajo y lo que cada grupo aporta al comparar resultados en clase, al final.

Grupo	Rol	Aporte principal
Grupo 1	**Legal y reporte**	La versión final del informe y la declaración explícita de lo que no se pudo verificar.
Grupo 2	**Rojo**	Evidencia cruda en semana_09/evidencia y el apartado de reproducción del informe.
Grupo 3	**Azul**	La mitigación aplicada, el comando de verificación y la comparación de resultados.
Grupo 4	**Púrpura**	La regla o consulta de detección y la tabla de lo detectado frente a lo ejecutado.

7 Qué se entrega

Playbook de una página, informe de triage y regla YARA probada, más post mortem.

Estructura de la carpeta `semana_09/`:

- README.md con integrantes, roles y tabla de semanas entregadas.
- semana_09/informe.md o informe.pdf con el entregable de esa práctica.
- semana_09/scripts/ con el código, con type hints y docstrings.
- semana_09/evidencia/ con salidas, capturas y hashes anonimizados.
- semana_09/README.md con el resumen de lo hecho y lo que no se pudo verificar.

Reglas que se verifican al corregir:

- Nada de secretos, tokens ni contraseñas en el repositorio; las claves van en .env ignorado.
- Nada de imágenes de disco, muestras de malware ni binarios: solo hashes y enlaces.
- Evidencia anonimizada: sin datos personales de terceros ni credenciales reales.
- Un commit por entrega con mensaje "semana NN: <entregable>".
- La práctica cuenta como entregada solo si está en el repositorio antes del corte.

8 Cómo se corrige

Criterio	Peso
Playbook operativo con fases y responsables	3,0
Triage estático completo y sin ejecutar la muestra	2,5
Regla YARA que detecta la muestra	2,0
Post mortem con mejoras priorizadas	1,5
Cumplimiento de las reglas de manejo de muestras	1,0
Total	**10,0**

9 Lista de verificación antes del corte

- El repositorio del grupo existe, es privado y el docente aparece como colaborador.
- La carpeta semana_09/ está en el repositorio, no solo en el equipo.
- El informe explica qué se hizo, con qué comandos y qué se obtuvo.
- La evidencia está anonimizada: sin datos personales, credenciales ni secretos.
- Cada hallazgo tiene su hash o su salida cruda que permite reproducirlo.
- El commit ’semana 09: <entregable>’ está hecho antes del corte.

Alcance y autorización: solo se trabaja sobre los contenedores del laboratorio o sobre sistemas con autorización escrita. Si el objetivo no está en ese conjunto, se detiene la práctica y se consulta al docente. El uso de estas técnicas fuera del alcance tiene consecuencias académicas y legales.

Recuerda

Dudas de la semana: se responden en clase o en el repositorio. Corte: Domingo 23:59 de la semana correspondiente; lo posterior no se corrige.

10 Glosario de la semana

Término	Definición
NIST SP 800-61	Guía de respuesta a incidentes con preparación, detección y análisis, contención, erradicación, recuperación y lecciones aprendidas.
Playbook	Procedimiento escrito con pasos, responsables y criterios de decisión para un tipo de incidente.
Contención	Limitar el alcance del incidente, aislando el equipo o cortando la cuenta, antes de erradicarlo y preservando la evidencia.
Triage	Clasificación rápida de un incidente o una muestra por gravedad, urgencia y confianza para decidir el siguiente paso.
YARA	Lenguaje de reglas para identificar muestras por cadenas y patrones binarios. Se valida contra muestras conocidas.
Análisis dinámico	Ejecutar la muestra en un entorno aislado y observar su comportamiento. El curso lo limita y nunca lo hace sobre el equipo real.
Post mortem	Informe posterior, sin culpables, que documenta cronología, decisiones, causas y acciones de mejora.